Proyecto Sprint 5 — Triage, Correlación e Informe bajo Presión en un SOC Real

Analista: Jose Iván Arango Franco

Fecha: 01/10/2026

Escenario: Lunes 09:00 AM. Cinco alertas críticas fueron cerradas como falsos positivos por compañeros de distintos turnos entre viernes y sábado, cada una investigada de forma aislada. Hay un ticket abierto pidiendo revisar la correlación del fin de semana. El supervisor: "No importa si fueron falsos positivos individualmente. Quiero saber si juntos cuentan otra historia." Tu misión: decidir si son 5 falsos positivos bien concluidos, o una sola campaña que pasó desapercibida.

Propósito: Dominar el triage operativo bajo presión, la correlación entre fuentes y la comunicación estructurada hacia un supervisor. Decidir con evidencia parcial sin caer en escalar por si acaso, ni cerrar sin mirar.

Este libro contiene los 4 entregables del proyecto. Completa cada hoja en orden.

Criterios de finalización — marca con X cuando completes cada punto

- X Revisé los 6 tickets (los 5 cerrados como FP y el abierto de Roberto)
- X Consulté las fuentes adicionales relevantes y encontré la entidad que aparece en varias alertas
- X Completé la matriz de triage para las 5 alertas (con señal/ruido y ancla común)
- X Escribí la nota de alcance con su corte explícito y el conflicto de datos
- X Armé la timeline con los niveles CONFIRMADO / INFERIDO / DESCONOCIDO marcados
- X Redacté el informe ejecutivo respetando la estructura fija de 4 bloques
- X Generé el PDF y lo entregué (link de Drive con comentarios habilitados, o ZIP)

Fase 1: Matriz de Triage — Evalúa capítulos 1 (Alertas) y 2 (Señal vs Falsos Positivos)

Para cada una de las 5 alertas del fin de semana, completa la matriz. Usa tu propio criterio del contexto del caso, no la justificación del analista que cerró antes.

Alerta / Ticket	Hipótesis de la regla (¿qué sospecha disparó la detección?)	¿Señal o Falso Positivo? (tu lectura)	Severidad SIEM (nominal)	Severidad Operativa (tu reasignación)	¿Correlacionar con otras? (Sí/No)	Punto común (usuario, host, IP, ventana temporal)
TKT-04102	Fuerza bruta o adivinación de credenciales contra una cuenta privilegiada (15 fallos en 5 min, no consta si el desbloqueo fue manual o por expiración automática del bloqueo temporal). Cierre sin contexto. El cron de esta cuenta entró bien el viernes 02:15, después de la rotación de contraseñas, así que "rotación no propagada" no se sostiene. El origen 10.50.8.45 sigue sin identificar y el login exitoso llegó 22 min después del bloqueo, sin registro de quién desbloqueó. Puede haber una explicación legítima no documentada, pero hoy no hay evidencia que la respalde.	SEÑAL. El cierre supone una rotación de contraseña no propagada, pero el cron de admin_backup entró bien el viernes a las 02:15, después del CHG-1842. Los intentos fueron a las 14:23, fuera de su ventana 02:00-04:00, y terminó en un login exitoso a las 14:48, 22 min después del bloqueo y sin registro de quién lo desbloqueó. AD mantiene la sesión activa desde entonces.	ALTA	MEDIA (activo central, pero por sí sola es un bloqueo y un login, sin daño verificable)	SÍ.	Usuario admin_backup; host srv-backup-01; IP 10.50.8.45, que reaparece en el login de las 18:45 (04118); ventana Vie 14:23–14:48 UTC. Es el primer evento conocido de la cadena.
TKT-04118	Uso indebido de una credencial legítima o reconocimiento (acceso fuera de horario a recursos sensibles de respaldos). Lectura de credentials_map.enc y otros archivos de configuración a las 18:45, fuera de su ventana y sin ticket ni mantenimiento. "Tal vez un técnico" es una suposición: el acceso interactivo corresponde a infra-team, y falta confirmar con ese equipo. Misma cuenta e IP que 04102.	SEÑAL. A las 18:45, fuera de su ventana, leyó hosts.conf, schedule.xml, credentials_map.enc y agents.list y listó snapshots. No hay ticket ni mantenimiento que lo respalde. El acceso interactivo corresponde a infra-team, no a la cuenta de servicio, y falta confirmar con ese equipo si fue trabajo suyo.	MEDIA	MEDIA (activo crítico y archivos sensibles, pero son lecturas de una cuenta con acceso al recurso y no hay evidencia de extracción por sí solas; sube si infra-team niega haber accedido)	SÍ.	Usuario admin_backup; host srv-backup-01; IP 10.50.8.45 (según AD); ventana Vie 18:45–18:47 UTC, unas 4 h después de 04102 y 3.5 h antes de la exfiltración de 04156.

Fase 1: Matriz de Triage — Evalúa capítulos 1 (Alertas) y 2 (Señal vs Falsos Positivos)

Para cada una de las 5 alertas del fin de semana, completa la matriz. Usa tu propio criterio del contexto del caso, no la justificación del analista que cerró antes.

Alerta / Ticket	Hipótesis de la regla (¿qué sospecha disparó la detección?)	¿Señal o Falso Positivo? (tu lectura)	Severidad SIEM (nominal)	Severidad Operativa (tu reasignación)	¿Correlacionar con otras? (Sí/No)	Punto común (usuario, host, IP, ventana temporal)
TKT-04156	Exfiltración de datos (transferencia de alto volumen a un destino externo fuera de la allowlist). Cierre por suposición. El dominio está fuera de la allowlist y es su primera resolución en 90 días; la IP no figura como destino de backup autorizado en CMDB ni tenía actividad previa desde ese host. EDR (22:12–22:15), DNS (22:14) y firewall (22:15:08) coinciden en la secuencia. Salieron 50 GB, y luego 18.4 y 4.2 GB más al mismo destino (~72.6 GB). El contenido se desconoce.	SEÑAL. El dominio cdn-us-east-19.streamcloud.io está fuera de la allowlist y es su primera resolución en 90 días; la IP 203.0.113.45 (VPS externo, AS64512) no figura como destino de backup autorizado en CMDB y no tenía actividad previa desde srv-backup-01. EDR registra un PowerShell codificado con padre rsync.exe a las 22:12, 2 a 3 min antes de la conexión de las 22:15:08. "Ventana extendida" no tiene ningún cambio aprobado que lo respalde en ITSM (el calendario está desactualizado).	ALTA	ALTA (~72.6 GB en tres salidas al mismo destino desde el activo más sensible; contenido y autorización sin confirmar; pasa a CRÍTICA si se confirma que los datos eran confidenciales o que nadie autorizó el destino)	SÍ.	Host srv-backup-01; usuario admin_backup (sesión activa en AD a las 22:15); IP destino 203.0.113.45 / streamcloud.io, que reaparece Sáb 03:00 (18.4 GB) y 07:30 (4.2 GB); ventana Vie 22:15–22:45 UTC.

Fase 1: Matriz de Triage — Evalúa capítulos 1 (Alertas) y 2 (Señal vs Falsos Positivos)

Para cada una de las 5 alertas del fin de semana, completa la matriz. Usa tu propio criterio del contexto del caso, no la justificación del analista que cerró antes.

Alerta / Ticket	Hipótesis de la regla (¿qué sospecha disparó la detección?)	¿Señal o Falso Positivo? (tu lectura)	Severidad SIEM (nominal)	Severidad Operativa (tu reasignación)	¿Correlacionar con otras? (Sí/No)	Punto común (usuario, host, IP, ventana temporal)
TKT-04203	Cambio no autorizado en la defensa perimetral (apertura de un canal de salida). Regla any:443 sin ticket de cambio y sin registro de retiro. Tener el permiso no es tener autorización, y no es una simple mejora de proceso. Se creó después de la primera salida de datos y antes de la segunda. El vínculo con el PowerShell de las 02:28 es inferido, no confirmado, por la incertidumbre de reloj entre fuentes.	SEÑAL. No hay ticket de cambio. admin_backup habilitó srv-backup-01 → any:443, mucho más amplio que un destino de backup; tener el permiso no equivale a estar autorizado. EDR registra un PowerShell codificado a las 02:28, pero con la incertidumbre de reloj entre fuentes no puede afirmarse que ese proceso aplicó la regla.	MEDIA	ALTA (sin registro de retiro, la regla expone la salida, sea o no intencional)	SÍ.	Usuario admin_backup; host srv-backup-01; ventana Sáb 02:30:15–02:30:22 UTC, entre las dos primeras salidas: después de los 50 GB del viernes y antes de la resolución DNS de streamcloud.io (02:55) y de los 18.4 GB de las 03:00.
TKT-04287	Escalada de privilegios (una cuenta obtiene control administrativo total del dominio). La cuenta se agregó a Domain Admins sin justificación ni cambio documentado, y no hay registro de que se haya revocado. El EDR lo respalda con net.exe desde PowerShell. Su hora (05:58) va 1m43s a 2m42s antes que AD (06:00:42); se corrigió a 05:59:43–06:00:42 como supuesto de deriva del reloj, no verificado. El cierre "sin acciones posteriores" es incorrecto: hubo 4.2 GB más de salida a las 07:30.	SEÑAL. La cuenta se agregó a sí misma a Domain Admins a las 06:00:42, sin justificación ni cambio documentado, desde srv-backup-01. EDR lo respalda con net.exe lanzado desde PowerShell (hora corregida a 05:59:43–06:00:42 por supuesto de deriva del reloj del EDR, no verificado) y la replicación a dc02 terminó a las 06:01:12.	CRÍTICA	CRÍTICA (riesgo sistémico sobre autenticación y servidores; sin registro de revocación del privilegio)	SÍ.	Usuario admin_backup; host de origen srv-backup-01; ventana Sáb 06:00:42–06:01:12 UTC. Cierra la secuencia: la IP 203.0.113.45 recibe 4.2 GB más a las 07:30.

Fase 2: Nota de Alcance — Evalúa capítulo 3 (Bajo presión)

El supervisor te dio 25 minutos para una nota inicial. Necesita poder decidir en 2 minutos de lectura. Completa cada elemento.

Elemento	Tu respuesta
1. Frase de primer vistazo Una sola frase que resuma la hipótesis dominante.	Las cinco alertas cerradas como falsos positivos forman una sola secuencia compatible con un compromiso de la cuenta, aunque el calendario desactualizado no permite descartar trabajo autorizado fuera del sistema de cambios.
2a. Alcance — Activos involucrados ¿Qué sistemas, cuentas o datos están en juego?	Servidor srv-backup-01 (respaldos primarios, criticidad ALTA); cuenta de servicio admin_backup (con alta a Domain Admins); controladores de dominio dc01 y dc02 (replicación del cambio); firewall perimetral (regla srv-backup-01 → any: 443); host 10.50.8.45 (origen de los intentos, sin identificar); destino externo 203.0.113.45 / cdn-us-east-19. streamcloud.io.
2b. Alcance — Datos en riesgo ¿Qué información podría verse comprometida?	Según CMDB, srv-backup-01 contiene snapshots de bases de datos productivas, credentials_map.enc, hashes de cuentas de servicio y la configuración de toda la infraestructura. Se leyeron archivos de configuración y credenciales, y salieron ~72.6 GB a un destino no registrado; el contenido exacto no está confirmado. Además, con Domain Admins sin registro de revocación, la autenticación del dominio queda en riesgo.
2c. Alcance — Período temporal ¿Qué ventana de tiempo cubre el incidente?	Desde Vie 25-sep-2026 14:23 UTC (primeros intentos fallidos) hasta Sáb 26-sep-2026 07:45 UTC (última actividad registrada). Los logs no cubren domingo ni lunes, por lo que no se sabe si la actividad continúa.
2d. Decisión recomendada Contener / Escalar / Monitorear — elige una y justifica brevemente.	ESCALAR. Hay actividad anómala sin cambio aprobado sobre el activo más crítico y no hay registro de que la regla any:443 se haya retirado ni de que el privilegio de Domain Admins se haya revocado. No elijo Monitorear por esa exposición abierta, ni Contener a ciegas porque el calendario está desactualizado y podría tratarse de trabajo autorizado sobre un servidor de respaldos. Escalar permite verificar hoy con infra-team y los jefes de equipo y, con autorización de Roberto, restringir la cuenta y retirar la regla sin aislar el servidor.
3. Orden de fuentes a consultar AD, firewall, proxy, endpoint, email — en qué orden y por qué.	Sigo contexto → identidad → red → aplicación, de lo más barato a lo más profundo. Contexto: 1) Calendario corporativo: primero descarto trabajo planificado, porque una ventana de mantenimiento cambiaría la lectura de todas las demás fuentes. Está desactualizado hace 2 semanas, así que un resultado vacío no descarta legitimidad y debe confirmarse con los jefes de equipo. 2) ITSM: la misma pregunta con la fuente oficial: ¿hay un cambio aprobado para la regla de firewall, el grupo de AD o el destino nuevo? 3) CMDB: criticidad de srv-backup-01, quién tiene acceso autorizado (admin_backup para jobs nocturnos, infra-team para acceso interactivo) y qué destinos están registrados; fija la línea base contra la que leo el resto de las fuentes. Identidad: 4) Active Directory: quién actuó, desde dónde y si la sesión sigue activa. Red: 5) Firewall: volumen y destino de la salida; con estas cinco fuentes ya se puede decidir escalar. 6) Proxy/DNS: primera resolución del dominio destino y su coincidencia con la IP. Aplicación: 7) Endpoint/EDR: proceso y linaje (PowerShell codificado con padre rsync.exe) detrás de la salida y los cambios. 8) Email: admin_backup es una cuenta de servicio sin buzón, así que aporta poco al vector de ingreso.

Fase 2: Nota de Alcance — Evalúa capítulo 3 (Bajo presión)

El supervisor te dio 25 minutos para una nota inicial. Necesita poder decidir en 2 minutos de lectura. Completa cada elemento.

Elemento	Tu respuesta
4. Conflicto de datos explicado Ej. un reloj desincronizado u otra inconsistencia entre fuentes.	Conflicto: el EDR registra el net.exe del alta a Domain Admins a las 05:58 (05:58:00–05:58:59);AD registra el cambio de grupo a las 06:00:42 y el DNS resuelve dc01 a las 06:00. El EDR va 1m43s a 2m42s antes, más que la resolución de los logs. Causa probable: no se puede determinar; puede ser atraso o deriva del reloj del EDR, latencia de ejecución del script o retraso de registro en AD. El viernes, EDR y firewall coinciden con menos de 1 minuto de diferencia (22:15 vs 22:15:08). Ajuste aplicado: +1m43s a +2m42s solo a ese evento, truncado a 06:00:42 porque el comando debe preceder al cambio en AD; queda en 05:59:43–06:00:42, como supuesto no verificado. Pendiente: verificar la sincronización NTP de srv-backup-01, del agente EDR y de dc01. Los eventos EDR de las 22:12 y 02:28 no se ajustaron porque no tienen una segunda fuente independiente.
5a. Corte explícito — Qué NO harás hoy Define el límite de tu investigación en este momento.	No haré forense profundo (volcado de memoria ni análisis del contenido de los ~72.6 GB). No investigaré movimiento lateral ni otros hosts más allá de srv-backup-01, dc01 y dc02. No aislaré srv-backup-01 sin autorización de Roberto, porque interrumpiría los respaldos. No atribuiré la actividad a un actor ni la declararé una intrusión confirmada.
5b. Corte explícito — Qué dato cambiaría tu decisión ¿Qué evidencia adicional alteraría tu recomendación?	Una confirmación documentada de infra-team o de los jefes de equipo de que el trabajo fue autorizado (incluido el destino 203.0.113.45 y la elevación a Domain Admins) bajaría la decisión a Monitorear con regularización. En sentido contrario, evidencia de actividad posterior al Sáb 07:45 o de que los datos enviados son confidenciales o regulados la subiría a Contener de inmediato.

Fase 3: Timeline Correlacionada — Evalúa capítulo 4 (Correlación y narrativa)

Toma las piezas que cuentan la misma historia y arma una sola línea de tiempo coherente. Clasifica cada evento. Normaliza desfases de reloj documentando el ajuste. Marca al menos un hueco de tiempo acotado: si faltan datos, declárlo — no inventes una hora exacta.

CONFIRMADO		INFERIDO		DESCONOCIDO	
Hora (normalizada)	**Fuente (AD/FW/proxy/EP/email)**	**Nivel de Certeza**	**Evento**	**Ajuste de reloj / Nota de desfase**	**Entidad ancla (usuario/host/IP)**
Vie, antes de 14:23:01	Sin datos	*DESCONOCIDO*	Vector de ingreso inicial, identidad del host 10.50.8.45 (origen de los intentos fallidos).	No aplica.	10.50.8.45 / admin_backup
Vie 14:23:01 – 14:48:03	AD	*CONFIRMADO*	Fallos de autenticación de admin_backup desde 10.50.8.45 hacia srv-backup-01 (5 de 15 visibles), bloqueo a las 14:25:11 por umbral de 15 intentos y login exitoso a las 14:48:03, 22m52s después, sin registro de razón o autor del desbloqueo. AD mantiene la sesión activa.	Sin ajuste.	admin_backup / 10.50.8.45 / srv-backup-01
Vie 18:45:22 – 18:47:15	AD / Ticket 04118	*CONFIRMADO*	Nuevo login desde 10.50.8.45 y lectura de hosts.conf, schedule.xml, credentials_map.enc y agents.list, más listado de snapshots, fuera de la ventana 02:00-04:00 de la cuenta.	Sin ajuste.	admin_backup / 10.50.8.45 / srv-backup-01

Fase 3: Timeline Correlacionada — Evalúa capítulo 4 (Correlación y narrativa)

Toma las piezas que cuentan la misma historia y arma una sola línea de tiempo coherente. Clasifica cada evento. Normaliza desfases de reloj documentando el ajuste. Marca al menos un hueco de tiempo acotado: si faltan datos, declárala — no inventes una hora exacta.

CONFIRMADO		INFERIDO		DESCONOCIDO	
Hora (normalizada)	**Fuente (AD/FW/proxy/EP/email)**	**Nivel de Certeza**	**Evento**	**Ajuste de reloj / Nota de desfase**	**Entidad ancla (usuario/host/IP)**
Vie 22:12 – 22:45:30	EP / Proxy / FW	*CONFIRMADO*	PowerShell codificado con padre rsync.exe (22:12), primera resolución en 90 días de cdn-us-east-19.streamcloud.io → 203.0.113.45 (22:14) y conexión HTTPS saliente desde powershell.exe (22:15:08). Salen 50.0 GB hasta el cierre a las 22:45:30.	Sin ajuste de reloj. EDR 22:15 coincide con FW 22:15:08 (diferencia de −8 s a +51 s, dentro de la resolución de ±59 s).	srv-backup-01 / admin_backup / 203.0.113.45
Sáb 02:30:15 – 02:30:22	FW	*CONFIRMADO*	admin_backup agrega la regla srv-backup-01 → any:443, la guarda y recarga el firewall, sin ticket de cambio. No hay registro de su retiro.	Sin ajuste.	admin_backup / srv-backup-01
Sáb 02:28 – 02:30:15	EP / FW	*INFERIDO*	El PowerShell codificado de las 02:28 (padre scheduled_task_runner.exe) sería el origen de la regla; no se confirma.	Sin ajuste de reloj (sin ancla independiente). La diferencia registrada es de 1m16s a 2m15s; con una deriva lineal hipotética del EDR (+56 a +89 s) pasaría a −13 s a +1m19s, por eso el orden no puede afirmarse.	srv-backup-01 / admin_backup
Sáb 02:55 – 03:45	Proxy / FW	*CONFIRMADO*	Nueva resolución de streamcloud.io → 203.0.113.45 (02:55) y 18.4 GB al mismo destino (03:00–03:45), ya con la regla any:443 creada.	Sin ajuste.	srv-backup-01 / 203.0.113.45

Fase 3: Timeline Correlacionada — Evalúa capítulo 4 (Correlación y narrativa)

Toma las piezas que cuentan la misma historia y arma una sola línea de tiempo coherente. Clasifica cada evento. Normaliza desfases de reloj documentando el ajuste. Marca al menos un hueco de tiempo acotado: si faltan datos, declárralo — no inventes una hora exacta.

CONFIRMADO		INFERIDO		DESCONOCIDO	
Hora (normalizada)	**Fuente (AD/FW/proxy/EP/email)**	**Nivel de Certeza**	**Evento**	**Ajuste de reloj / Nota de desfase**	**Entidad ancla (usuario/host/IP)**
Sáb 05:59:43 – 06:00:42 (corregido desfase +01m43s a +02m42s)	EP	*INFERIDO*	El EDR registra net.exe localgroup "Domain Admins" admin_backup /ADD (padre powershell.exe); se lo toma como origen del alta registrada en AD en la fila siguiente (mismo host, cuenta y grupo).	Registrado 05:58 (05:58:00–05:58:59) vs AD 06:00:42: diferencia de 1m43s a 2m42s. Se corrigió y se truncó en 06:00:42 porque el comando debe preceder al cambio. Es un supuesto de atraso del reloj del EDR, no verificado: puede ser latencia del script y entonces la hora real es 05:58. El viernes EDR y FW coinciden en menos de 1 min. El rango es la diferencia observada con AD, no un desfase medido de forma independiente; la corrección solo ubica el evento antes del límite causal (06:00:42).	admin_backup / srv-backup-01
Sáb 06:00:42 – 06:01:12	AD	*CONFIRMADO*	admin_backup se agrega a sí misma a Domain Admins desde srv-backup-01, sin justificación ni cambio documentado; la replicación a dc02 termina a las 06:01:12. No hay registro de revocación.	Sin ajuste. Es la hora de referencia del efecto en AD; el DNS a dc01 (06:00) es consistente.	admin_backup / srv-backup-01 / dc01
Sáb 07:30 – 07:45	FW	*CONFIRMADO*	4.2 GB al mismo destino con la cuenta ya en Domain Admins.	Sin ajuste.	srv-backup-01 / 203.0.113.45

Fase 3: Timeline Correlacionada — Evalúa capítulo 4 (Correlación y narrativa)

Toma las piezas que cuentan la misma historia y arma una sola línea de tiempo coherente. Clasifica cada evento. Normaliza desfases de reloj documentando el ajuste. Marca al menos un hueco de tiempo acotado: si faltan datos, declárlo — no inventes una hora exacta.

CONFIRMADO		INFERIDO		DESCONOCIDO	
Hora (normalizada)	**Fuente (AD/FW/proxy/EP/email)**	**Nivel de Certeza**	**Evento**	**Ajuste de reloj / Nota de desfase**	**Entidad ancla (usuario/host/IP)**
Sáb 07:45 en adelante	Sin datos	*DESCONOCIDO*	Si la actividad continúa (los logs no cubren domingo ni lunes) y si hubo trabajo autorizado fuera del sistema de cambios (calendario desactualizado, sin confirmar con jefes de equipo).	No aplica.	admin_backup / srv-backup-01 / 203.0.113.45
Hueco de tiempo declarado:		Sáb 06:01:12 → 07:30:00 (1h28m48s). No hay eventos en ninguna fuente justo después de que admin_backup obtiene Domain Admins, así que no se sabe qué hizo con esos privilegios. Otras franjas sin eventos: Vie 22:45:30 → Sáb 02:25 (~3h39m) y Sáb 03:45 → 05:59:43 (~2h14m). Se cerraría con los logs de AD y EDR de esa franja y con la sincronización NTP de srv-backup-01, el agente EDR y dc01.			

Cierre — La historia en 4 líneas (sin floritura):

Una misma cuenta de respaldos actuó fuera de su rutina: entró de forma sospechosa, revisó información sensible, sacó grandes volúmenes de datos hacia un destino desconocido y se otorgó el máximo nivel de permisos, sin un cambio aprobado que lo respalde. Como el calendario de mantenimientos está desactualizado y falta confirmar trabajo no registrado, una explicación legítima no se descarta. Hoy el patrón es anómalo y debe escalarse, aunque se ignora qué datos salieron, cómo empezó y si continúa.

Fase 4: Informe Ejecutivo para Supervisor (máximo 12 líneas)

Estructura fija obligatoria. Evita los dos extremos: un informe estilo 'podría / tal vez' en todo, y un informe sin evidencia estilo 'APT confirmado'.

1. CONFIRMADO

Hechos con fuente.

Vie 14:23–Sáb 07:45 UTC: admin_backup leyó credentials_map.enc y srv-backup-01 envió ~72.6 GB a 203.0.113.45, no registrado como destino autorizado en CMDB.
Sin ticket de cambio (ITSM): regla any:443 (Sáb 02:30) y alta a Domain Admins (Sáb 06:00), hechas por la propia cuenta.
El EDR registra PowerShell codificado lanzado por rsync.exe (Vie 22:12) y por una tarea programada (Sáb 02:28).

2. PROBABLE

Hipótesis con indicadores que la sustentan.

Las cinco alertas son una sola secuencia, compatible con compromiso de admin_backup: fuera de su ventana y de su rol.
El mismo PowerShell codificado habría ejecutado salida, regla y alta (inferido; reloj EDR corregido, no verificado).
Los ~72.6 GB serían exfiltración desde srv-backup-01 (volumen, destino sin registro, snapshots y credenciales en el host).

3. DESCONOCIDO

Gap explícito + por qué importa.

Contenido de los ~72.6 GB, vector inicial e identidad de 10.50.8.45: definen el impacto real y el punto de entrada.
Si la actividad continúa y si regla y privilegios siguen activos (logs terminan Sáb 07:45): define el alcance en el dominio.
Si hubo trabajo autorizado fuera del sistema de cambios (calendario desactualizado): define incidente vs. actividad legítima.

4. ACCIONES

Una acción inmediata + una para cerrar el gap.

Inmediata: escalar a IR hoy y, con autorización de Roberto, restringir admin_backup y retirar la regla any:443.
Cerrar el gap: confirmar con jefes si fue autorizado y recuperar logs de AD y EDR desde Sáb 06:01, con revisión NTP.